RÉFÉRENCE · ANALYSE DE RISQUE

Conduire une analyse de risque **cyber**

La méthode et les chiffres — d'EBIOS Risk Manager à la quantification FAIR, et comment défendre un risque devant une direction.

Fondations du risque | EBIOS RM · ANSSI | FAIR · Monte-Carlo | Biais de l'expert | Décision & comité

Public Analyste SOC confirmé · master cybersécurité
Format Manuel de référence, le pourquoi autant que le comment
Édition Octobre 2026 · sources ANSSI, Open FAIR, ISO vérifiées

RÉDIGÉ PAR
0xKuraishY

Sommaire

Huit chapitres et quatre annexes. Un cas fil rouge les traverse de bout en bout.

00 Avant-propos — pourquoi ce manuel existe 3

01 Les fondations : menace, vulnérabilité, impact, vraisemblance, risque 4

02 Risque inhérent, risque résiduel, et le piège de l'ordre des mesures 8

03 EBIOS Risk Manager — la méthode de l'ANSSI, atelier par atelier 10

04 Quantifier avec FAIR — décomposer le risque en facteurs mesurables 18

05 Estimer par intervalles, distributions et simulation de Monte-Carlo 22

06 Les biais cognitifs de l'expert qui note — et comment les réduire 28

07 Du risque à la décision — défendre un chiffre devant une direction 32

A Sources vérifiées & bibliographie annotée (liens) 36

B Glossaire croisé EBIOS RM, FAIR et ISO 27005 38

C Fiches-réflexes : paramètres du cas fil rouge & formules 39

D Check-list de l'analyste & modèle de note au COMEX 40

Convention de lecture — chaque chapitre s'ouvre sur **l'idée clé en une phrase**, déroule **le raisonnement**, l'illustre d'un **exemple chiffré**, signale les **pièges fréquents** et se referme sur un **À retenir**. Les passages **BioVax** suivent une entreprise fictive de biotechnologie — le même cas que celui du guide ANSSI, prolongé ici jusqu'au chiffrage et à la décision.

CHAPITRE 00 — AVANT-PROPOS

Pourquoi ce manuel, **pour qui**, et contre quoi

Vous savez déjà lire une alerte, corréler des logs et reconstituer une kill chain. Ce que le terrain réclame ensuite, c'est autre chose : transformer cette compréhension technique en une *décision d'allocation de ressources* que votre direction pourra assumer. C'est précisément la zone grise entre le SOC et le COMEX que ce document veut éclairer — non pas « comment noter un risque de 1 à 4 », mais *pourquoi* telle échelle existe, ce qu'elle cache, et comment la dépasser quand l'enjeu le mérite.

Le marché de l'analyse de risque est saturé de matrices colorées remplies au jugé, de « probabilités » qui n'en sont pas, et de plans d'action dont personne ne sait s'ils réduisent quoi que ce soit. Ce manuel prend le contre-pied en articulant deux familles complémentaires : la méthode **EBIOS Risk Manager** de l'ANSSI, excellente pour *construire des scénarios* défendables et structurer le dialogue avec les métiers ; et le cadre **FAIR / Open FAIR**, qui apporte la *rigueur quantitative* pour chiffrer ces scénarios en euros et en probabilités. Les deux ne s'opposent pas : EBIOS cadre le *quoi*, FAIR mesure le *combien*.

> Un risque qu'on ne sait pas chiffrer est un risque qu'on ne sait pas arbitrer. Un risque qu'on chiffre sans honnêteté sur l'incertitude est pire encore : il déguise une opinion en fait.

Le fil conducteur est une entreprise fictive mais réaliste, **BioVax**, fabricant de vaccins — le cas pédagogique officiel du guide ANSSI, que nous prolongeons jusqu'à la simulation Monte-Carlo et la note de décision. Tous les chiffres de ce document proviennent de simulations réellement exécutées (200 000 itérations), afin que les ordres de grandeur se tiennent et que vous puissiez reproduire la démarche.

I UN MOT SUR L'ACTUALITÉ RÉGLEMENTAIRE

La transposition française de la directive **NIS2** replace l'analyse de risque au cœur des obligations des entités essentielles et importantes. Le **Référentiel Cyber France (ReCyF)**, publié par l'ANSSI le 17 mars 2026, décline NIS2 en objectifs de sécurité vérifiables et s'appuie sur une logique d'appréciation du risque proportionnée à la maturité de l'entité. EBIOS RM reste la méthode de référence côté français ; FAIR gagne du terrain pour la restitution financière au conseil d'administration. Savoir manier les deux n'est plus un luxe.

CHAPITRE 01 — FONDATIONS

Menace, vulnérabilité, impact, **vraisemblance**, risque

L'IDÉE CLÉ EN UNE PHRASE

Le risque n'est pas une chose que l'on possède, c'est une **mesure prospective** : la combinaison de la fréquence probable d'un événement de perte et de son ampleur probable — jamais un simple adjectif accolé à un actif.

— Le raisonnement — cinq mots que tout le monde confond

Avant toute méthode, il faut purger le vocabulaire. Quatre-vingts pour cent des mauvaises analyses tiennent à une confusion entre des termes qu'on croit synonymes et qui désignent des objets distincts. Posons-les proprement, car chaque méthode — EBIOS, FAIR, ISO — les relie différemment.

Une **menace** est tout ce qui est capable d'agir de manière à causer un préjudice : un acteur malveillant, une erreur humaine, une défaillance, un événement naturel. Dans le vocabulaire FAIR, l'agent concret s'appelle *threat agent* ; côté EBIOS, on parle de **source de risque (SR)**, caractérisée par sa motivation, ses ressources et ses modes opératoires. La menace existe indépendamment de vous — vous ne la réduisez pas, vous réduisez votre exposition à elle.

Une **vulnérabilité** n'est pas « une CVE ». C'est, au sens du risque, la *probabilité qu'un événement de menace devienne un événement de perte*. Autrement dit : sachant qu'un attaquant agit, quelle chance a-t-il de réussir ? FAIR la définit avec une précision redoutable comme la probabilité que la *capacité de la menace* (TCap) dépasse la *force de résistance* (RS) de vos contrôles. Une CVE non exploitable dans votre contexte ne contribue pas à la vulnérabilité du scénario ; un défaut de cloisonnement trivial, lui, peut la faire monter à près de 1.

> **!** PIÈGE FRÉQUENT — « VULNÉRABILITÉ » = « LISTE DE CVE »
>
> Empiler un scan de vulnérabilités dans un rapport de risque, c'est confondre une *cause possible* avec la *probabilité conditionnelle de succès*. Une vulnérabilité ne devient pertinente qu'au sein d'un scénario : un acteur, un chemin, un actif. Hors scénario, un CVSS 9.8 sur un service non exposé et sans valeur métier ne « vaut » rien. Posez toujours la question FAIR : *cette faiblesse change-t-elle la probabilité qu'une tentative réussisse contre cet actif-là ?*

L'**impact** — la *gravité* en langage EBIOS, la *loss magnitude* en langage FAIR — mesure l'intensité des effets si le risque se réalise. Le réflexe de débutant est de le réduire au coût technique de remédiation. Le réflexe d'auteur est de le décomposer en *formes de perte* (nous y venons au chapitre 4) et de distinguer la **perte primaire** (subie directement : productivité, réponse, remplacement) de la **perte secondaire** (infligée par la réaction de

tiers : amendes, réputation, perte d'avantage concurrentiel). Confondre les deux conduit à sous-estimer massivement les scénarios touchant des données personnelles ou des secrets industriels.

La **vraisemblance** est le mot le plus maltraité du métier. EBIOS la définit comme l'estimation de la *faisabilité ou de la probabilité* qu'un scénario se réalise, sur une échelle ordinale (V1 à V4). FAIR va plus loin : la vraisemblance d'un événement de perte (LEF) se décompose en *fréquence d'événement de menace* (TEF) multipliée par *vulnérabilité*. La nuance est capitale : dire « ce risque est probable » n'a de sens que rapporté à une *fenêtre de temps*. « 0,2 occurrence par an » et « 20 % de chances sur l'année » décrivent la même réalité ; « probable » tout court n'en décrit aucune.

> « Possible » est binaire : une chose arrive ou n'arrive pas. « Probable » est un continuum entre l'impossible et le certain. Une direction ne peut arbitrer qu'avec du probable — jamais avec du possible.

Enfin le **risque** lui-même. Sa définition FAIR, la plus opérationnelle, est : *la fréquence probable et l'ampleur probable d'une perte future*. Deux nombres, pas un adjectif. EBIOS le formalise comme un **scénario de risque** complet — de la source de risque jusqu'à l'objectif visé, en passant par un chemin d'attaque et son scénario opérationnel — puis le positionne par sa gravité et sa vraisemblance. ISO 27005:2022, enfin, aligne ce vocabulaire sur la logique générale d'ISO 31000. Les trois cadres disent la même chose avec des mots différents ; l'annexe B les met en correspondance ligne à ligne.

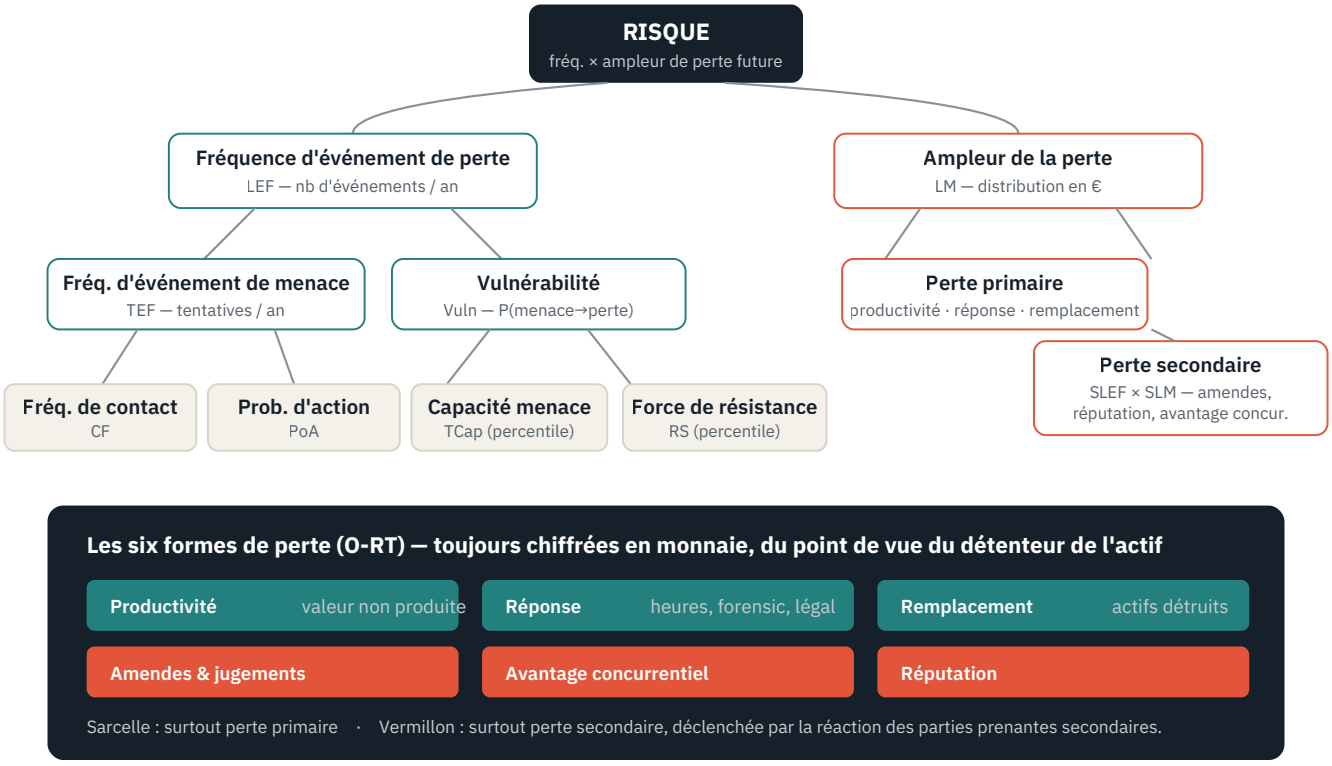


Figure 1. La taxonomie Open FAIR. Le risque se décompose en deux branches indépendantes : la fréquence d'événement de perte (gauche, sarcelle) et l'ampleur de la perte (droite, vermillon). Chaque nœud est mesurable, et l'analyste choisit librement le niveau d'abstraction auquel il estime — par exemple directement la TEF plutôt que CF × PoA. Cette liberté est ce qui rend FAIR praticable sur le terrain.

Exemple chiffré — le même incident, trois vocabulaires

Chez BioVax, un concurrent cherche à exfiltrer les données de R&D vaccin. Traduisons l'unique réalité dans les trois langages :

> **FIL ROUGE BIOVAX — TRADUCTION CROISÉE**
>
> **EBIOS** — Source de risque : *Concurrent*. Objectif visé : *voler des informations de R&D pour un avantage concurrentiel*. Événement redouté : *fuite des travaux de recherche*, gravité **G3 (grave)**. Scénario opérationnel via le prestataire informatique : vraisemblance **V4 (quasi-certain)**.
>
> **FAIR** — Threat community : concurrent outillé mais non étatique (TCap ≈ 70e percentile). TEF ≈ 0,4 à 4 tentatives/an. Le prestataire, faiblement durci, fait monter la vulnérabilité à ≈ 0,8. LEF résultante ≈ 0,22 événement/an. Loss magnitude dominée par la perte d'avantage concurrentiel (secondaire).
>
> **ISO 27005** — Un « événement redouté » devient une « conséquence » ; une « valeur métier » devient un « bien primaire » ; une « partie prenante » devient une « partie intéressée ». Même objet, étiquettes normatives.

Remarquez ce que la traduction révèle : EBIOS vous a donné un *scénario défendable* et une priorité relative ; FAIR vous a donné des *nombres* qui, injectés dans une simulation (chapitre 5), produiront une perte annuelle attendue en euros. L'un n'est pas meilleur que l'autre ; ils opèrent à des étages différents de la même pyramide.

> ✓ **À RETENIR**
>
> Cinq mots, cinq objets distincts. La **menace** agit, la **vulnérabilité** est une probabilité conditionnelle de succès, l'**impact** se décompose en pertes primaires et secondaires, la **vraisemblance** n'a de sens que par unité de temps, et le **risque** est *deux* nombres — fréquence et ampleur — jamais un adjectif. Toute méthode sérieuse relie ces cinq objets ; aucune ne les confond.

CHAPITRE 02 — INHÉRENT & RÉSIDUEL

Risque inhérent, risque résiduel, et **l'ordre des mesures**

L'IDÉE CLÉ EN UNE PHRASE

Le risque **inhérent** est ce que vous subiriez sans aucun contrôle ; le risque **résiduel** est ce qui subsiste après traitement — et la seule erreur impardonnable est de compter dans le résiduel des mesures qui ne sont pas encore en place.

Le raisonnement — trois états d'un même risque

Un même scénario de risque se lit à trois moments. Le **risque inhérent** (ou intrinsèque) suppose l'absence de tout contrôle : c'est une abstraction utile pour mesurer la valeur d'un dispositif de sécurité, rarement observable en pratique. Le **risque courant** intègre les contrôles réellement déployés aujourd'hui — chez EBIOS, c'est le socle de sécurité de l'atelier 1 qui joue ce rôle. Le **risque résiduel** est ce qui demeure *après* l'application de la stratégie de traitement décidée en atelier 5. C'est ce dernier que la direction accepte formellement.

La question que tout COMEX finit par poser — « de combien ce plan réduit-il le risque ? » — n'a de réponse honnête que si l'on sait distinguer ces états et les chiffrer. FAIR excelle ici : en modélisant la vulnérabilité comme la probabilité que TCap dépasse RS, un renforcement de contrôle se traduit mécaniquement par une hausse de RS, donc une baisse de la vulnérabilité, donc de la LEF, donc de la perte annuelle attendue. Le delta est *calculable*.

> **!** PIÈGE FRÉQUENT — ANTICIPER UNE MESURE NON IMPLÉMENTÉE
>
> Le guide ANSSI est explicite et l'avertissement mérite d'être encadré en rouge : *on ne peut réduire le niveau de dangerosité d'une partie prenante que si la mesure est effectivement mise en œuvre avant la suite de l'analyse.* Compter dès maintenant l'effet d'un audit prévu dans neuf mois, c'est fabriquer un risque résiduel fictivement bas — et endormir une direction sur un danger encore bien présent. Règle d'or : le résiduel ne bouge que lorsque le contrôle *fonctionne*, pas lorsqu'il est *budgété*.

Exemple chiffré — ce que « réduire le risque » veut dire en euros

Chez BioVax, notre simulation Monte-Carlo (détaillée au chapitre 5) donne pour le risque *courant* une perte annuelle attendue de **0,85 M€**, avec un quantile à 95 % de 5,2 M€. Si l'on remontait au risque *inhérent* — prestataires non audités, R&D non cloisonnée, aucune supervision — la même simulation produit une perte annuelle attendue d'environ **5,7 M€** et près d'une chance sur deux de subir au moins un incident dans l'année.

Le socle de sécurité existant absorbe donc déjà l'essentiel. Le plan de traitement, lui, fait passer le *résiduel* attendu à **0,26 M€**.

5,7	0,85	0,26
M€ — perte annuelle attendue, risque inhérent (sans contrôle)	M€ — risque courant, socle existant en place	M€ — risque résiduel visé après plan de traitement

Le gain du plan est donc d'environ **0,59 M€ par an** de perte annuelle attendue évitée, pour un coût de mise en œuvre estimé à 0,38 M€ amorti : un retour sur investissement sécurité (ROSI) positif, de l'ordre de **+55 %**. Ce raisonnement — qui n'a rien d'évident à produire avec une matrice ordinale — est exactement ce qui fait basculer un arbitrage en comité. Nous le défendrons au chapitre 7.

> ✓ **À RETENIR**
>
> Trois états : inhérent (sans contrôle), courant (socle en place), résiduel (après traitement décidé). La **valeur d'un contrôle** est le delta entre deux de ces états — et elle ne se compte qu'une fois le contrôle *opérant*. Chiffrer ce delta en euros, c'est transformer « on a sécurisé » en « on a évité 0,59 M€ de perte annuelle attendue pour 0,38 M€ ».

La méthode de l'ANSSI, **atelier par atelier**

L'IDÉE CLÉ EN UNE PHRASE

EBIOS RM combine une **approche par conformité** pour les risques communs et une **approche par scénarios** pour les attaques ciblées, en descendant du plus stratégique (les missions) vers le plus technique (les biens supports) à travers cinq ateliers qui s'alimentent par itérations.

Le raisonnement — pourquoi cinq ateliers, et pas une matrice

La force d'EBIOS RM, dans sa version 1.5 de septembre 2024 — désormais pleinement conforme à ISO 27005:2022 — n'est pas de produire une note, mais de *structurer un dialogue* entre la direction, les métiers, le RSSI et la DSI. La méthode refuse le piège de la matrice remplie en chambre : elle part des **missions** de l'organisation, en déduit ce qui mérite protection, puis confronte systématiquement le point de vue du défenseur (qu'est-ce qui me ferait mal ?) et celui de l'attaquant (qui m'en veut, et comment procéderait-il ?).

Cette bascule de perspective est la signature méthodologique. L'atelier 1 adopte l'œil du défenseur ; les ateliers 2 à 4 adoptent celui de l'attaquant ; l'atelier 5 réconcilie les deux dans une décision. La « pyramide du management du risque numérique » traduit cette idée : le socle de conformité traite les risques de masse, l'appréciation par scénarios se concentre sur les attaques avancées, là où elle apporte le plus de valeur.

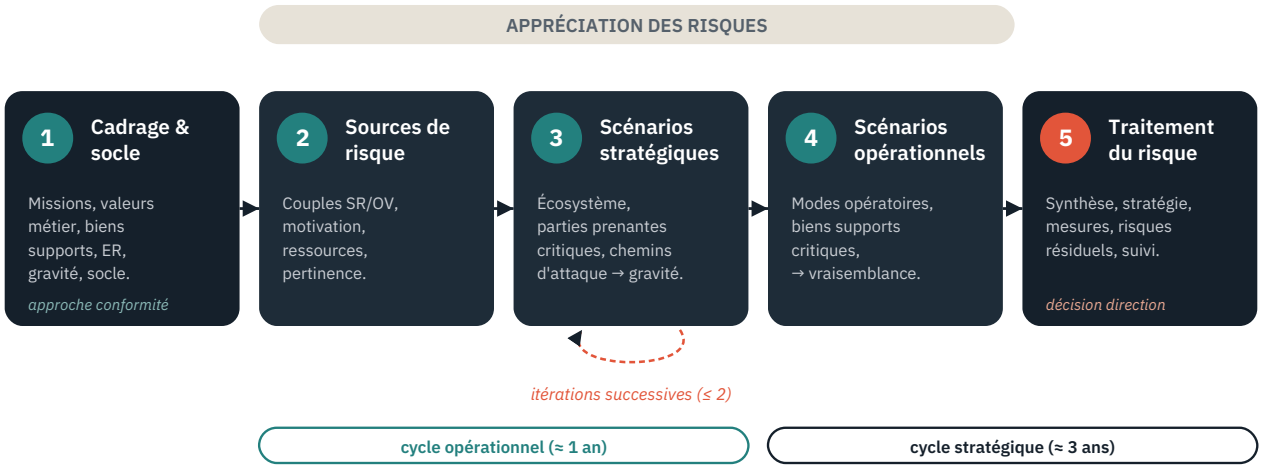


Figure 2. La démarche itérative en cinq ateliers. Les ateliers 1 et 5 (encadrés sombres) réunissent la direction ; ce sont les points de décision. Les ateliers 3 et 4 s'alimentent par itérations successives — au plus deux, pour ne pas noyer l'analyse. La gravité naît en atelier 3, la vraisemblance en atelier 4 ; leur croisement, en atelier 5, donne le niveau de risque.

Atelier 1 — Cadrage et socle de sécurité

On y définit le périmètre, on recense les **missions**, les **valeurs métier** (les biens essentiels à protéger) et les **biens supports** qui les portent. On identifie les **événements redoutés (ER)** et on cote leur **gravité** sur quatre niveaux, de G1 (mineure) à G4 (critique). On évalue enfin la conformité au **socle de sécurité** — guides d'hygiène ANSSI, PSSI interne, exigences clients, famille ISO 27000, réglementation applicable.

I VOLUMÉTRIE RECOMMANDÉE PAR L'ANSSI

Cinq à dix valeurs métier suffisent généralement à orienter l'étude ; un à trois biens supports par valeur métier au départ. L'objectif n'est pas l'exhaustivité mais la *pertinence* — on garde l'agilité pour itérer. Identifier dès cette étape *qui* sera responsable d'accepter les risques résiduels est indispensable : sans décideur nommé, l'atelier 5 tournera à vide.

FIL ROUGE BIOVAX — ATELIER 1

Mission : *identifier et fabriquer des vaccins*. Valeurs métier retenues : *R&D* (processus), *fabrication* (processus), *traçabilité & contrôle qualité* (information). Quelques ER cotés : *fuite des travaux de R&D* → G3 ; *altération des résultats de contrôle qualité aboutissant à une non-conformité sanitaire* → G4 ; *interruption de production > 1 semaine pendant un pic épidémique* → G4. Socle : guide d'hygiène ANSSI « appliqué avec restrictions » — compte d'administration non nominatif sur l'ERP, politique de sauvegarde en cours de rédaction.

! PIÈGE FRÉQUENT — S'ÉPUISER SUR LE SOCLE, OUBLIER L'ARBITRAGE DE SORTIE

Le guide prévoit une décision explicite à la fin de l'atelier 1 : si les écarts au socle sont *trop significatifs*, on **ne poursuit pas** les ateliers suivants — il est vain d'évaluer des attaques sophistiquées sur un système vulnérable aux risques les plus courants. Beaucoup d'équipes enchaînent mécaniquement vers l'atelier 2 alors que leur énergie devrait d'abord aller au renforcement du socle. Sachez vous arrêter.

Atelier 2 — Sources de risque

On répond à une seule question : *qui ou quoi pourrait porter atteinte aux missions et valeurs métier, et dans quel but ?* On produit des couples **source de risque / objectif visé (SR/OV)**, qu'on évalue sur trois critères — **motivation**, **ressources**, **activité** — pour n'en retenir que les plus pertinents. Trois à six couples suffisent à nourrir les scénarios stratégiques.

Tableau 1. Extrait de la cartographie des sources de risque de BioVax — évaluation de la pertinence des couples SR/OV (atelier 2).

Source de risque	Objectif visé	Motivation	Ressources	Activité	Pertinence
Concurrent	Voler les travaux de R&D	Importante	Significatives	Importante	Élevée
Activiste	Saboter la campagne de vaccination	Modérée	Modérées	Faible	Moyenne
Activiste	Divulguer les tests animaliers	Faible	Faibles	Faible	Faible
Cybercriminel	Extorsion via altération des vaccins	Modérée	Significatives	Faible	Faible

L'équipe retient en priorité le *concurrent* et l'*activiste saboteur*, met la menace cybercriminelle sous surveillance, et écarte provisoirement la divulgation des tests animaliers. Noter la justification de chaque cotation (une colonne dédiée) est ce qui permettra de réévaluer sans tout refaire au cycle suivant.

> **! PIÈGE FRÉQUENT — CONFONDRE OBJECTIF VISÉ ET MOTIVATION**
>
> L'*objectif visé* est l'effet recherché (voler des informations) ; la *motivation* est ce qui pousse la source à le poursuivre (gain financier, idéologie, vengeance). Les mélanger brouille l'évaluation de pertinence et fausse la suite. Un même objectif peut être porté par des motivations très différentes, avec des ressources et une persévérance incomparables.

— Atelier 3 — Scénarios stratégiques

On cartographie l'**écosystème** — partenaires, prestataires, clients — et on estime le **niveau de dangerosité** de chaque partie prenante, sur des critères d'*exposition* (dépendance, pénétration) et de *fiabilité cyber* (maturité, confiance). Les plus dangereuses deviennent des **parties prenantes critiques (PPC)** : le « maillon faible » qu'un attaquant bien renseigné visera en priorité, par moindre effort. On bâtit alors des **chemins d'attaque** de haut niveau, dont la gravité hérite de celle des événements redoutés.

> **FIL ROUGE BIOVAX — ATELIER 3**
>
> Trois PPC retenues : le *prestataire informatique* (F3, accès privilégié + sécurité faible), un *fournisseur de matériel* (F2) et un *laboratoire* partenaire (P3). Pour le couple Concurrent/Vol-R&D, trois chemins : exfiltration directe ; via le laboratoire P3 ; via le prestataire F3. Pour le couple Activiste/Sabotage, deux chemins : arrêt de production via F2, et altération de l'étiquetage. Le sabotage en pic épidémique est coté **G4** ; le vol de R&D, **G3**.

— Atelier 4 — Scénarios opérationnels

On descend au niveau technique : les **modes opératoires** concrets, structurés par une séquence d'attaque (type *cyber kill chain*, ou le découpage *Connaître → Rentrer → Trouver → Exploiter*). On représente ces scénarios en **graphes d'attaque**, avec des opérateurs *ET* / *OU* entre actions élémentaires. Puis on estime la **vraisemblance globale** de chaque scénario sur quatre niveaux, de V1 (peu vraisemblable) à V4 (quasi-certain), en confrontant les ressources de la source au niveau de vulnérabilité réel de l'écosystème.

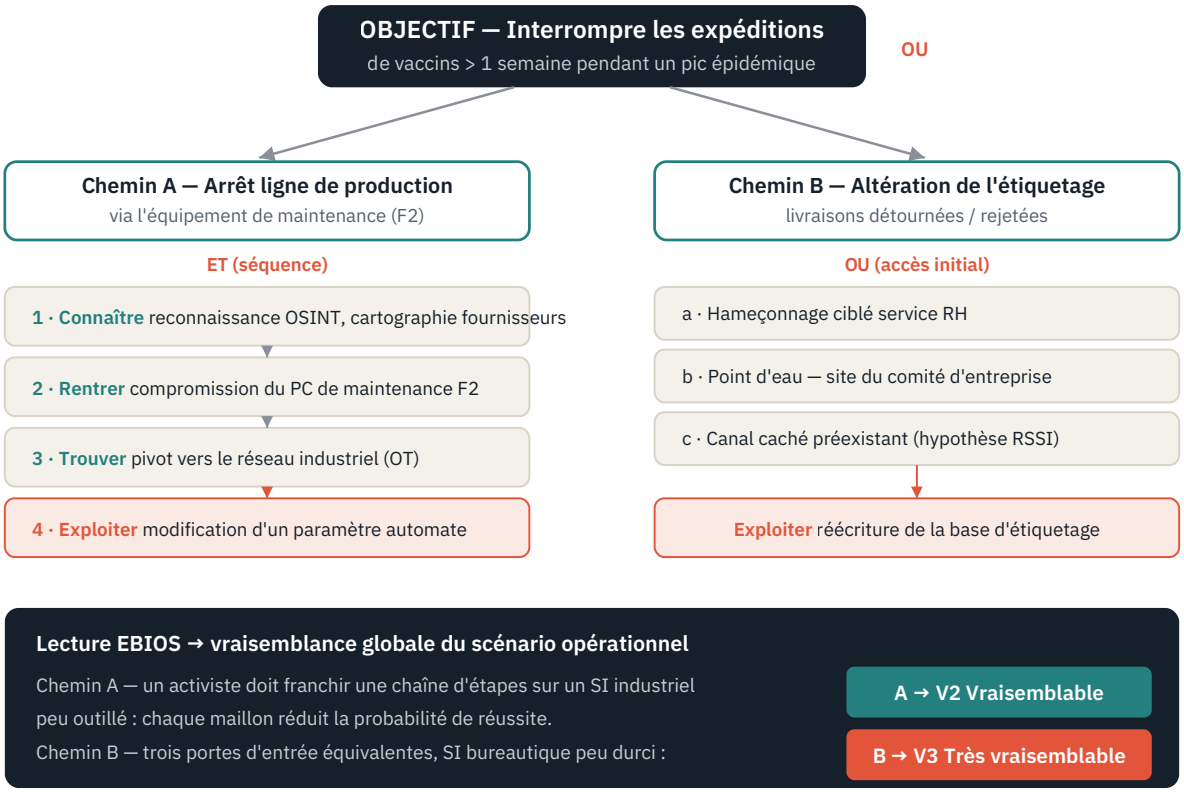


Figure 3. Arbre d'attaque du sabotage de production (cas BioVax). Deux chemins exclusifs (opérateur OU) atteignent l'objectif. Le chemin A exige une *séquence* (ET) d'étapes sur un SI industriel peu accessible — chaque maillon abaisse la probabilité, d'où une vraisemblance V2. Le chemin B offre trois portes d'entrée équivalentes sur un SI bureautique peu durci — d'où V3. L'arbre rend visible *pourquoi* les deux vraisemblances diffèrent.

I VRAISEMBLANCE ÉLÉMENTAIRE VS GLOBALE

On peut coter chaque *action élémentaire* puis composer — approche fine, utile quand on dispose de données — ou estimer directement la vraisemblance *globale* du mode opératoire de moindre effort — approche express, plus rapide mais moins traçable. Le choix dépend de la maturité de l'équipe et de l'enjeu. Pour un scénario qui déclenchera un investissement lourd, prenez le temps de la cotation élémentaire : elle rend l'estimation défendable.

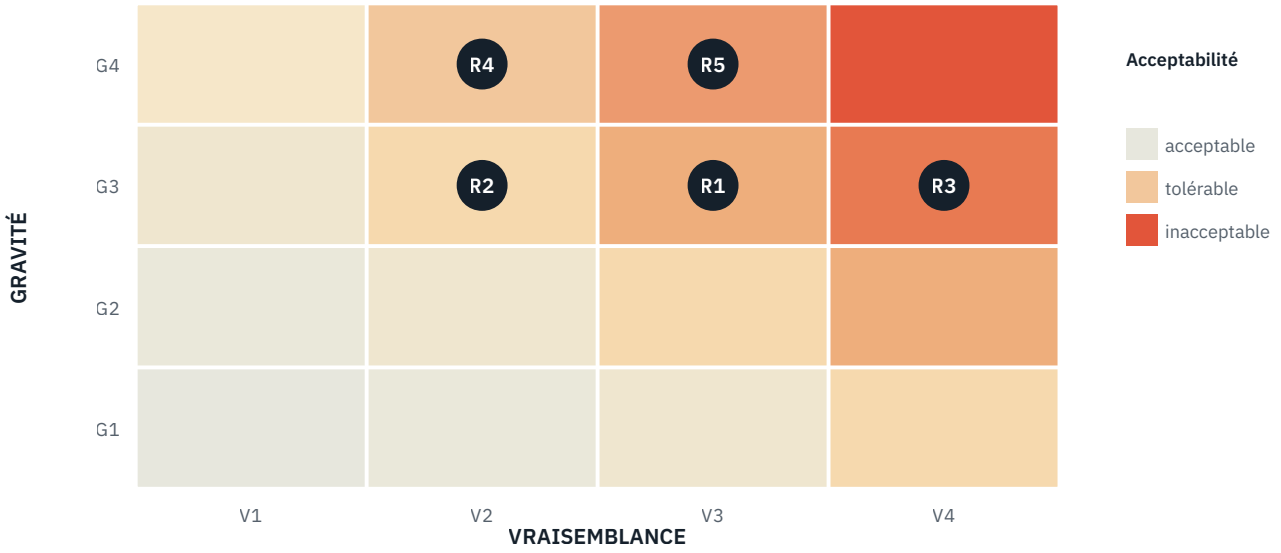
FIL ROUGE BIOVAX — VRAISEMBLANCES RETENUES (ATELIER 4)

Vol via le prestataire F3 → **V4 quasi-certain** (droits élevés + sécurité faible du prestataire rendent l'intrusion très facile). Vol par exfiltration directe → **V3 très vraisemblable** (utilisateurs peu sensibilisés, réseaux non cloisonnés, flux sortants non supervisés). Vol via le laboratoire P3 → **V2**. Sabotage via F2 → **V2**. Altération d'étiquetage → **V3**.

— Atelier 5 — Traitement du risque

On synthétise les scénarios de risque sur une **matrice gravité × vraisemblance** (diagramme de Farmer), on décide d'une **stratégie de traitement** (réduire, accepter, transférer, éviter) au regard de seuils d'acceptation, on formalise les **mesures** dans un plan de traitement structuré (gouvernance, protection, défense, résil-

lience), puis on évalue et documente les **risques résiduels** et on installe le **cadre de suivi** — indicateurs, comité de pilotage, déclencheurs de réévaluation.



Positions issues de l'atelier 5 du cas fil rouge. R3 (vol via le prestataire) est le point le plus à droite : gravité grave, vraisemblance quasi-certaine.

Figure 4. Cartographie du risque initial (atelier 5). Les cinq scénarios de BioVax positionnés par gravité et vraisemblance. R3 (vol via le prestataire) occupe l'angle le plus défavorable : grave *et* quasi-certain. R4 et R5 (sabotage) sont critiques en gravité mais moins vraisemblables. Cette carte ordonne les priorités ; elle ne dit pas *combien* — c'est le rôle de FAIR, au chapitre suivant.

Tableau 2. Les cinq scénarios de risque de BioVax et leur niveau initial (avant traitement).

Réf.	Scénario de risque	Gravité	Vraisemb.	Niveau
R1	Vol de R&D par exfiltration directe	G3	V3	Élevé
R2	Vol de R&D via le laboratoire (P3)	G3	V2	Moyen
R3	Vol de R&D via le prestataire (F3)	G3	V4	Élevé
R4	Arrêt de production via F2	G4	V2	Élevé
R5	Perturbation par altération d'étiquetage	G4	V3	Élevé

I LE PLAN DE TRAITEMENT SE STRUCTURE EN QUATRE AXES

Gouvernance (clauses contractuelles, procédures de signalement), **protection** (chiffrement, cloisonnement, contrôle d'accès), **défense** (sondes IDS, analyse de journaux) et **résilience** (PCA renforcé). Chaque mesure porte un responsable, une échéance, un coût et un statut. Le suivi s'appuie sur des indicateurs et un comité de pilotage semestriel en montée en puissance, annuel en rythme de croisière.

! PIÈGE FRÉQUENT — LA MATRICE ORDINALE PRISE POUR UNE MESURE

Une matrice 4×4 ordonne des priorités ; elle ne mesure rien. On ne peut ni additionner deux risques « élevés », ni dire que passer de V3 à V2 « divise le risque par deux », ni agréger un portefeuille. Deux scénarios dans la même case peuvent différer d'un facteur dix en euros. Utilisez la matrice EBIOS pour *cadrer et communiquer* ; basculez vers FAIR dès qu'il faut *arbitrer un budget* ou *comparer* finement. Le chapitre 6 détaille pourquoi les échelles ordinales induisent en erreur.

✓ À RETENIR

Cinq ateliers, deux points de décision (1 et 5), deux perspectives (défenseur puis attaquant). EBIOS RM ne produit pas un chiffre : il produit des **scénarios défendables**, une **cartographie de l'écosystème** et une **priorisation partagée** avec les métiers et la direction. Sa valeur est dans la *structure du dialogue*, pas dans la couleur des cases — qu'il faut savoir dépasser quand l'enjeu réclame des euros.

CHAPITRE 04 — QUANTIFICATION FAIR

Décomposer le risque en **facteurs mesurables**

L'IDÉE CLÉ EN UNE PHRASE

FAIR ne vous demande pas de « deviner le risque » : il le **décompose** en facteurs suffisamment petits pour être estimés honnêtement, puis les recombine par des relations mathématiques explicites jusqu'à une perte exprimée en euros.

— Le raisonnement — pourquoi décomposer change tout

Demandez à un expert « quel est le risque de fuite de R&D ? » et vous obtiendrez un haussement d'épaules ou un chiffre sorti de nulle part. Demandez-lui plutôt : « combien de fois par an un concurrent tente-t-il quelque chose contre cette donnée ? », « quelle fraction de ces tentatives réussirait, vu nos contrôles ? », « si ça réussit, combien de jours d'arrêt ? », « quel coût par jour ? » — et soudain chaque sous-question devient estimable. C'est tout le principe de **Factor Analysis of Information Risk** : la décomposition rend mesurable ce qui paraissait intangible.

Le standard **Open FAIR** de l'Open Group formalise cette décomposition en deux documents — le *Risk Taxonomy* (O-RT) et le *Risk Analysis* (O-RA), dont les éditions courantes sont respectivement la version 3.1 et la version 2.1, publiées le 22 mai 2025 pour intégrer la fonction *Govern* du NIST CSF 2.0. La taxonomie (revue en Figure 1) scinde le risque en deux branches que l'on estime séparément :

BRANCHE GAUCHE — LA FRÉQUENCE (LEF)

- **TEF** (Threat Event Frequency) : combien de fois, par unité de temps, un agent agit contre l'actif. Elle-même se décompose en fréquence de contact (CF) × probabilité d'action (PoA) si l'on veut descendre d'un cran.
- **Vuln** (Vulnérabilité) : la probabilité qu'une tentative réussisse, soit la probabilité que la **capacité de la menace (TCap)** dépasse la **force de résistance (RS)** des contrôles. Deux percentiles qu'on fait s'affronter.

LEF = TEF × Vuln. L'analyste choisit librement son niveau d'abstraction : estimer directement la TEF si les données de contact manquent, descendre à CF × PoA si elles existent.

BRANCHE DROITE — L'AMPLEUR (LM)

La **Loss Magnitude** se lit en deux temps. La **perte primaire** frappe directement le détenteur de l'actif : productivité, réponse, remplacement. La **perte secondaire** naît de la réaction des *parties prenantes secondaires* (clients, régulateurs, médias) qui deviennent, en quelque sorte, de nouveaux agents de menace : amendes, perte d'avantage concurrentiel, atteinte à la réputation. Elle se chiffre comme une **fréquence conditionnelle (SLEF)** × une **ampleur secondaire (SLM)**.

Les **six formes de perte** canoniques — productivité, réponse, remplacement, amendes et jugements, avantage concurrentiel, réputation — forment une check-list exhaustive. Les oublier, c'est sous-estimer ; les compter deux fois, c'est gonfler. La discipline FAIR est précisément de les passer toutes en revue, une à une, pour chaque scénario.

> **PIÈGE FRÉQUENT — RÉDUIRE L'IMPACT À LA PERTE PRIMAIRE**
>
> Pour un vol de secret industriel, la perte primaire (forensic, réponse) est souvent dérisoire face à la perte secondaire : l'avantage concurrentiel évaporé peut se chiffrer en années de marge. Inversement, pour une panne purement interne sans tiers affecté, inventer une perte secondaire « réputationnelle » gonfle artificiellement le chiffre. Chaque forme de perte doit être *justifiée* par un mécanisme concret, pas invoquée par réflexe.

Au-delà d'Open FAIR — les extensions du FAIR Institute

Le FAIR Institute a étendu le modèle historique par deux standards utiles à connaître. **FAIR-CAM** (Controls Analytics Model, v1.0, janvier 2025) décrit la « physiologie » des contrôles : comment ils agissent individuellement et *en système* sur la fréquence et l'ampleur, en trois domaines (contrôles d'événement de perte, de gestion de la variance, d'aide à la décision). **FAIR-MAM** (Materiality Assessment Model) affine la perte en un modèle de coûts détaillé, pensé notamment pour les obligations de divulgation de matérialité. Ces extensions ne remplacent pas Open FAIR ; elles l'outillent pour l'automatisation et le reporting financier.

Exemple chiffré — le scénario R1 décomposé

> **FIL ROUGE BIOVAX — DÉCOMPOSITION FAIR DU VOL DE R&D (R1)**
>
> **Fréquence.** TEF estimée par intervalle : IC 90 % = [0,4 ; 4] tentatives/an. Vulnérabilité, vu le socle courant (réseau non cloisonné, flux non supervisés), modélisée par une PERT (min 0,04 ; mode 0,12 ; max 0,30). LEF moyenne résultante ≈ **0,22 événement/an**.
>
> **Ampleur.** Perte primaire : durée d'arrêt des travaux PERT(2 ; 5 ; 14) jours × coût/jour PERT(0,25 ; 0,35 ; 0,60) M€, plus réponse et remplacement. Perte secondaire : avantage concurrentiel, déclenché dans 40 % des cas (SLEF), d'ampleur lognormale IC 90 % = [0,2 ; 6] M€. Perte moyenne par événement ≈ **3,8 M€**.

Multiplier naïvement 0,22 × 3,8 donnerait une perte annuelle attendue d'environ 0,85 M€ — et c'est effectivement l'ordre de grandeur. Mais ce produit de moyennes *cache la forme de la distribution* : la plupart des années ne verront aucune perte, quelques-unes une perte modérée, et de rares années une perte catastrophique. C'est précisément ce que le produit de moyennes ne peut pas dire — et pourquoi il faut simuler. C'est l'objet du chapitre suivant.

> **À RETENIR**
>
> FAIR décompose le risque jusqu'à des facteurs estimables : **LEF = TEF × Vuln** pour la fréquence, **pertes primaires + secondaires** réparties en six formes pour l'ampleur. La vulnérabilité y est l'affrontement **TCap vs RS** — ce qui rend l'effet d'un contrôle *calculable*. Open FAIR (O-RT 3.1 / O-RA 2.1) fournit la taxonomie ; FAIR-CAM et FAIR-MAM l'outillent pour les contrôles et la matérialité.

CHAPITRE 05 — ESTIMATION & SIMULATION

Intervalles, distributions et **Monte-Carlo**

L'IDÉE CLÉ EN UNE PHRASE

On n'estime jamais un risque par un nombre unique mais par un **intervalle calibré** traduit en **distribution de probabilité** ; la simulation de Monte-Carlo propage alors ces incertitudes jusqu'à une **distribution de pertes**, dont on lit la moyenne, les quantiles et la queue.

Le raisonnement — du point à l'intervalle, de l'intervalle à la loi

Un expert sommé de donner « le » coût d'un incident se trompera presque toujours, et de beaucoup. Le même expert, à qui l'on demande un *intervalle à 90 %* — « je suis sûr à 90 % que le coût tombe entre X et Y » — produit une estimation bien plus honnête, parce qu'elle avoue son ignorance au lieu de la masquer. C'est le cœur de la démarche d'Hubbard et Seiersen : un intervalle calibré vaut mieux qu'un faux point précis.

Reste à donner une *forme* à cet intervalle. Trois lois suffisent à couvrir l'essentiel des besoins :

- La **PERT** (une Beta reparamétrée par min / mode / max) quand un expert a une intuition du cas le plus probable et des bornes : idéale pour une durée d'arrêt, un coût unitaire.
- La **lognormale** quand la grandeur est strictement positive et peut exploser : parfaite pour une perte financière à « queue épaisse », où l'improbable catastrophe compte.
- La **triangulaire**, plus grossière, quand on ne veut pas sur-spécifier la forme : un recours honnête faute de mieux.

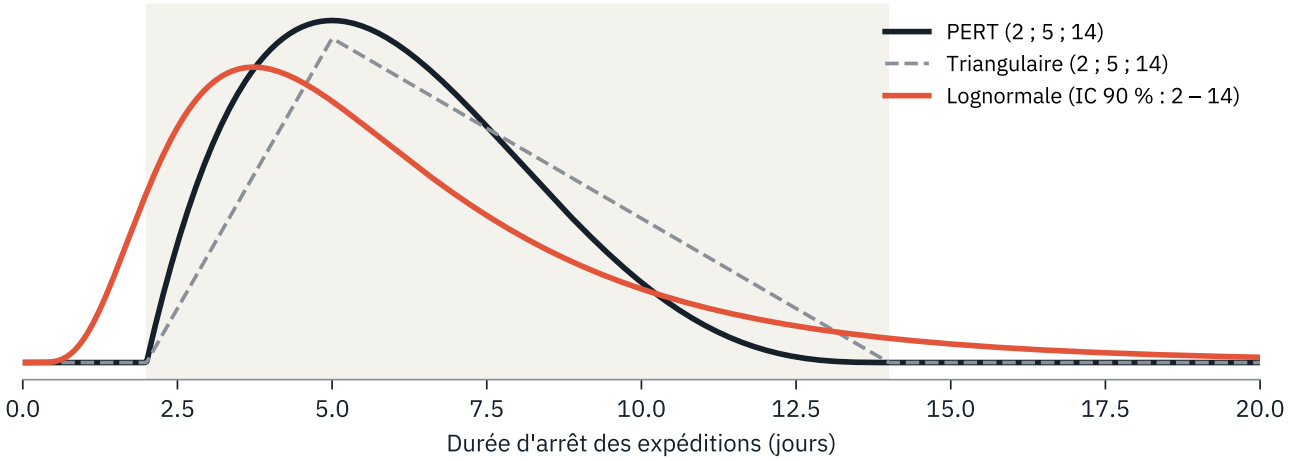


Figure 5. Trois lois pour un même avis d'expert. « Entre 2 et 14 jours d'arrêt, le plus probable étant 5 ». La PERT concentre la masse autour du mode ; la lognormale (calée sur l'IC 90 % 2–14) étire une queue vers les scénarios longs ; la triangulaire reste linéaire. Le choix de la forme n'est pas cosmétique : il décide du poids des événements rares, donc des quantiles élevés.

La simulation de Monte-Carlo, concrètement

Le principe tient en une phrase : on *rejoue l'année* des dizaines de milliers de fois. À chaque itération, on tire au hasard une valeur dans chaque distribution d'entrée (TEF, Vuln, durée, coût…), on en déduit le nombre d'événements de l'année (un tirage de Poisson de paramètre LEF) et la perte de chacun, et on additionne. Au bout de 200 000 années simulées, l'histogramme des pertes annuelles *est* la réponse : non pas un chiffre, mais une distribution complète.

> **I** POURQUOI 200 000 ITÉRATIONS ?
>
> Parce que les décisions se jouent dans la *queue* de la distribution — les quantiles à 95 % et 99 % — et qu'estimer un événement rare demande beaucoup de tirages pour être stable. Pour une perte annuelle attendue, quelques milliers suffisent ; pour un P99 fiable, on vise la centaine de milliers. La simulation de ce manuel tourne à 200 000 itérations, graine fixée, pour que les chiffres soient reproductibles.

Exemple chiffré — la distribution de pertes de BioVax

En injectant les distributions FAIR du scénario de vol de R&D dans une simulation de Monte-Carlo, on obtient la Figure 6. Elle se lit en trois temps.

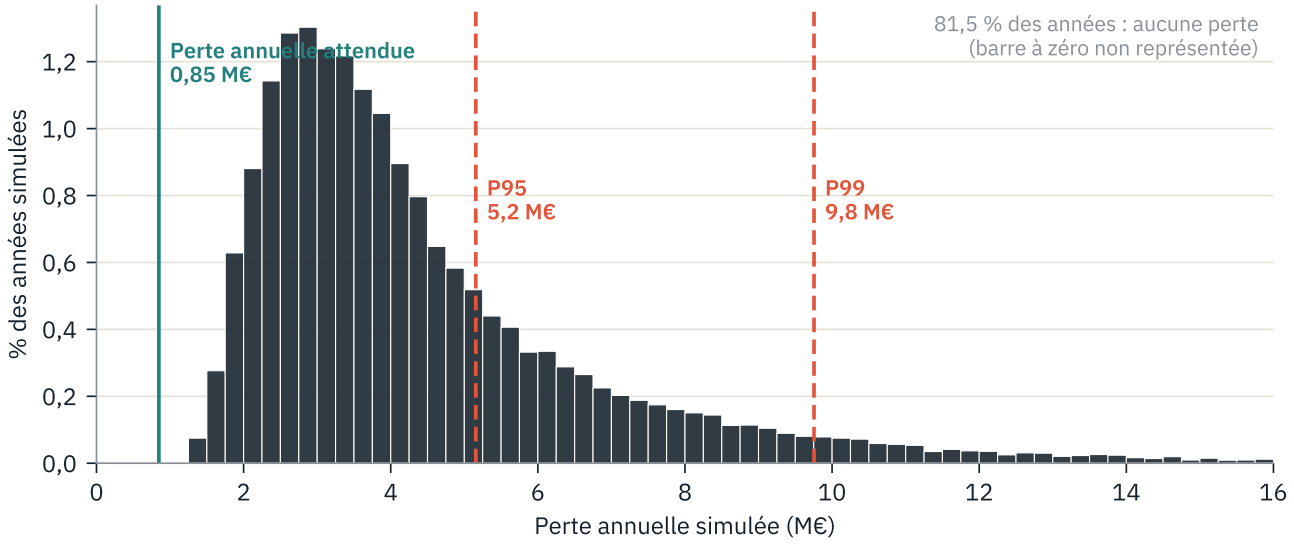


Figure 6. Distribution des pertes annuelles (situation courante, 200 000 années simulées). La grande majorité des années ne voit *aucune* perte (barre à zéro non représentée). Parmi les années touchées, les pertes se concentrent autour de 3–4 M€, mais la queue s'étire bien au-delà. La **perte annuelle attendue** (0,85 M€) est tirée vers le bas par toutes les années à zéro ; elle ne décrit *aucune* année typique — d'où l'importance des quantiles.

18,5	**0,85**	**5,2**	**9,8**
% des années subissent au moins une perte	M€ — perte annuelle attendue (moyenne)	M€ — quantile à 95 % (1 année sur 20)	M€ — quantile à 99 % (1 année sur 100)

! PIÈGE FRÉQUENT — CONFONDRE LA MOYENNE ET LE CAS TYPIQUE

La perte annuelle attendue de 0,85 M€ ne correspond à *aucune* année réelle : la plupart valent zéro, quelques-unes valent 3 à 5 M€. Présenter la seule moyenne à un comité, c'est laisser croire à une saignée régulière et modérée, alors que le vrai sujet est une *loterie à faible fréquence et forte amplitude*. Toujours accompagner la moyenne d'un quantile de queue (P95, P99) — c'est là que se décide le dimensionnement d'une cyber-assurance.

— La courbe d'excédance des pertes — l'outil de décision

La représentation reine, pour arbitrer, n'est pas l'histogramme mais la **courbe d'excédance des pertes** (Loss Exceedance Curve). Elle répond directement à la question de la direction : « quelle est la probabilité de perdre *plus* de X ? ». On y superpose la **tolérance au risque** déclarée par le conseil — et l'on voit immédiatement où le risque la dépasse.

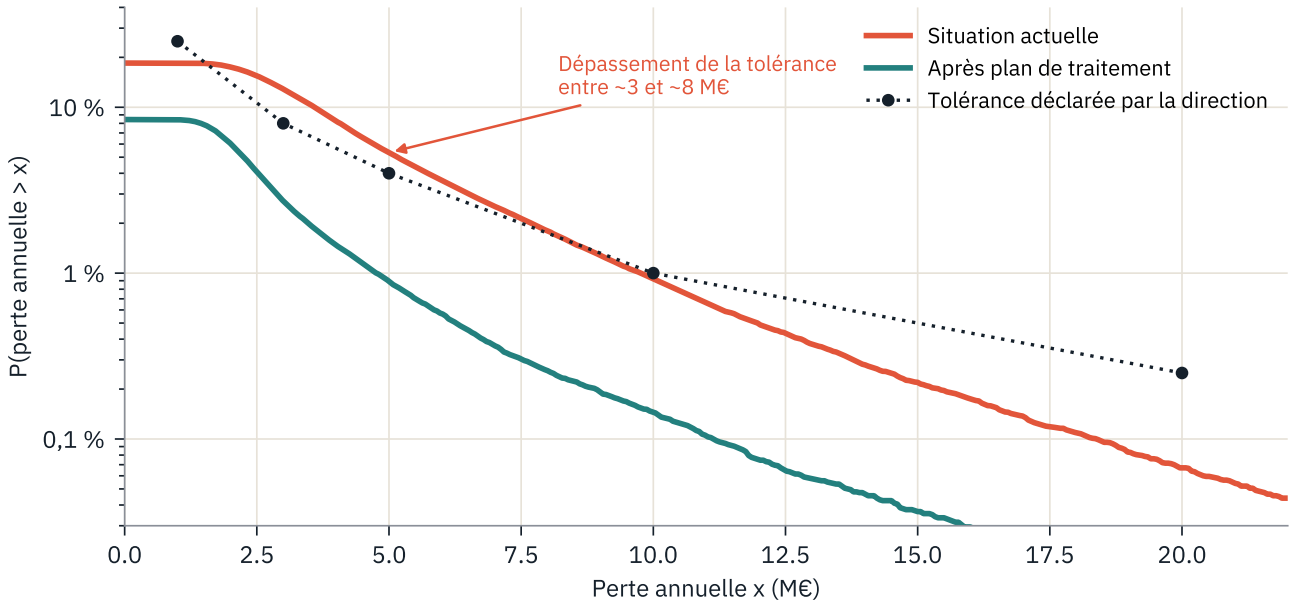


Figure 7. Courbe d'excédance des pertes, avant/après traitement. La courbe vermillon (situation actuelle) dépasse la courbe de tolérance de la direction (pointillés) entre ~3 et ~8 M€ : c'est la zone qui justifie l'action. Après plan de traitement (sarcelle), la courbe repasse presque partout sous la tolérance. Cette image — plus qu'un tableau — *déclenche la décision* : elle montre un risque qui excède l'appétit déclaré, et un plan qui le ramène dans les clous.

Savoir ce qui compte — l'analyse de sensibilité

Avant de dépenser un euro, il faut savoir *quel facteur* gouverne le résultat. L'analyse de sensibilité (diagramme « tornado ») fait varier chaque entrée de son P10 à son P90, toutes choses égales par ailleurs, et classe les facteurs par amplitude d'effet sur la perte annuelle attendue. On y apprend souvent que l'incertitude se concentre sur deux ou trois variables — et donc où porter l'effort de mesure et de contrôle.

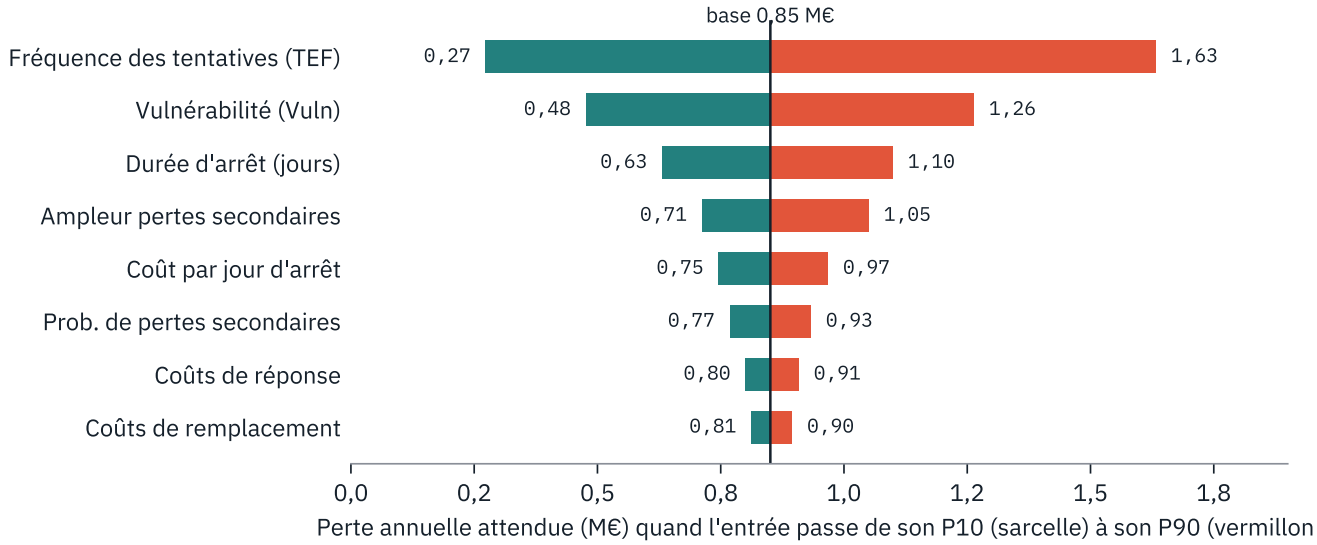


Figure 8. Diagramme tornado — ce qui pilote la perte annuelle attendue. La *fréquence des tentatives* (TEF) et la *vulnérabilité* dominent largement : réduire la vulnérabilité (cloisonnement, supervision) agit directement sur les deux barres du haut. À l'inverse, raffiner l'estimation des coûts de remplacement (bas) ne changerait presque rien. Conclusion opérationnelle : investir dans la réduction de vulnérabilité, pas dans la précision comptable.

✓ **À RETENIR**

On estime en **intervalles calibrés**, on leur donne une **forme** (PERT, lognormale, triangulaire), on propage par **Monte-Carlo** jusqu'à une distribution de pertes. On en tire la moyenne *et* les quantiles (P95, P99), on la confronte à la tolérance via la **courbe d'excédance**, et on priorise l'effort grâce au **tornado**. La moyenne ne décrit jamais une année réelle : c'est la queue qui décide.

CHAPITRE 06 — BIAIS DE L'EXPERT

Les biais cognitifs de celui qui **note le risque**

L'IDÉE CLÉ EN UNE PHRASE

L'instrument de mesure du risque, c'est le **jugement humain** — et comme tout instrument, il a des défauts systématiques qu'on peut mesurer, entraîner et corriger ; ignorer ces biais revient à mesurer avec une règle tordue sans le savoir.

Le raisonnement — l'analyste est l'instrument

Qu'on utilise EBIOS ou FAIR, les nombres entrent par une seule porte : l'estimation d'un expert. Or la recherche en psychologie de la décision est sans appel : nos jugements probabilistes sont biaisés de façon *systématique*, donc prévisible, donc corrigeable. Les connaître n'est pas un supplément d'âme ; c'est une exigence de qualité de la mesure, au même titre que l'étalonnage d'un capteur.

LES BIAIS QUI FAUSSENT LA FRÉQUENCE ET LA VRAISEMBLANCE

La **disponibilité** fait surestimer ce qui vient facilement à l'esprit : au lendemain d'un rançongiciel médiatisé, toutes les cotations de vraisemblance montent, indépendamment de la réalité du terrain. L'**ancrage** enchaîne l'estimation au premier chiffre entendu — un « 80 % » lancé en réunion aspire toutes les réponses suivantes. La **représentativité** fait juger un scénario probable parce qu'il est *détaillé et cohérent*, alors qu'ajouter des détails ne peut que *réduire* sa probabilité (c'est l'erreur de conjonction : « attaque par le prestataire, un vendredi soir, via un PC de maintenance » est forcément moins probable que « attaque par le prestataire »).

LES BIAIS QUI FAUSSENT L'IMPACT ET LA CONFIANCE

L'**excès de confiance** est le plus documenté et le plus dangereux : sommés de donner un intervalle à 90 %, la plupart des experts produisent des intervalles bien trop étroits — la vraie valeur tombe hors de leur fourchette bien plus de 10 % du temps. L'**optimisme** et le biais du *planning fallacy* font sous-estimer durées et coûts de remédiation. Enfin la **pensée de groupe** et l'effet de **conformité** font converger un atelier vers l'avis du plus gradé ou du plus bavard, étouffant les signaux divergents — un comble pour une méthode collaborative comme EBIOS.

! PIÈGE FRÉQUENT — L'ÉCHELLE ORDINALE QUI FABRIQUE DE FAUX CONSENSUS

Les échelles 1–4 aggravent les biais au lieu de les contenir. « 3 » ne veut pas dire la même chose pour deux personnes, l'écart entre « 2 » et « 3 » n'est pas défini, et la couleur de la case donne une illusion de précision. Pire : elles autorisent des opérations interdites (moyenner des rangs, additionner des « élevés »). Hubbard montre que ces matrices peuvent *dégrader* la qualité de décision sous le hasard pur. Préférez des probabilités et des intervalles explicites dès que l'enjeu le justifie.

Comment réduire les biais — des techniques qui marchent

La bonne nouvelle : ces biais se corrigent, et les techniques sont documentées. Cinq d'entre elles méritent d'entrer dans votre routine.

1. **L'entraînement à la calibration.** On soumet l'expert à des batteries de questions à réponse connue en lui demandant des intervalles à 90 %, puis on lui montre son taux de réussite réel. En trois ou quatre sessions, la plupart des gens passent de 60–70 % de réussite à 85–90 % — ils apprennent à *élargir* leurs intervalles jusqu'à l'honnêteté. C'est la mesure la plus rentable du chapitre.
2. **Le test de l'équivalent-pari.** Pour vérifier un intervalle, demandez à l'expert : « préférez-vous parier que la valeur tombe dans votre fourchette, ou faire tourner une roue avec 90 % de chances de gagner ? » S'il préfère la roue, son intervalle est trop étroit ; s'il préfère le pari, trop large. On ajuste jusqu'à l'indifférence.
3. **L'estimation individuelle avant la mise en commun.** Chacun écrit son estimation *avant* toute discussion, pour casser l'ancrage et la conformité. On révèle ensuite, on explore les écarts — ce sont eux qui sont instructifs — puis on reconverge. Variante structurée : la méthode Delphi.
4. **Le « prémortem ».** Avant de figer une estimation, on imagine qu'on est dans un an et que l'incident a eu lieu : « racontez pourquoi ». L'exercice débloque des scénarios que l'optimisme avait masqués et élargit la distribution d'impact.
5. **La décomposition.** C'est le pont avec FAIR : estimer « le risque » est impossible, estimer TEF, Vuln, durée et coût séparément est faisable. La décomposition réduit mécaniquement l'arbitraire, car chaque sous-facteur s'ancre sur des données ou une expérience plus directe.

Exemple chiffré — l'effet de la calibration

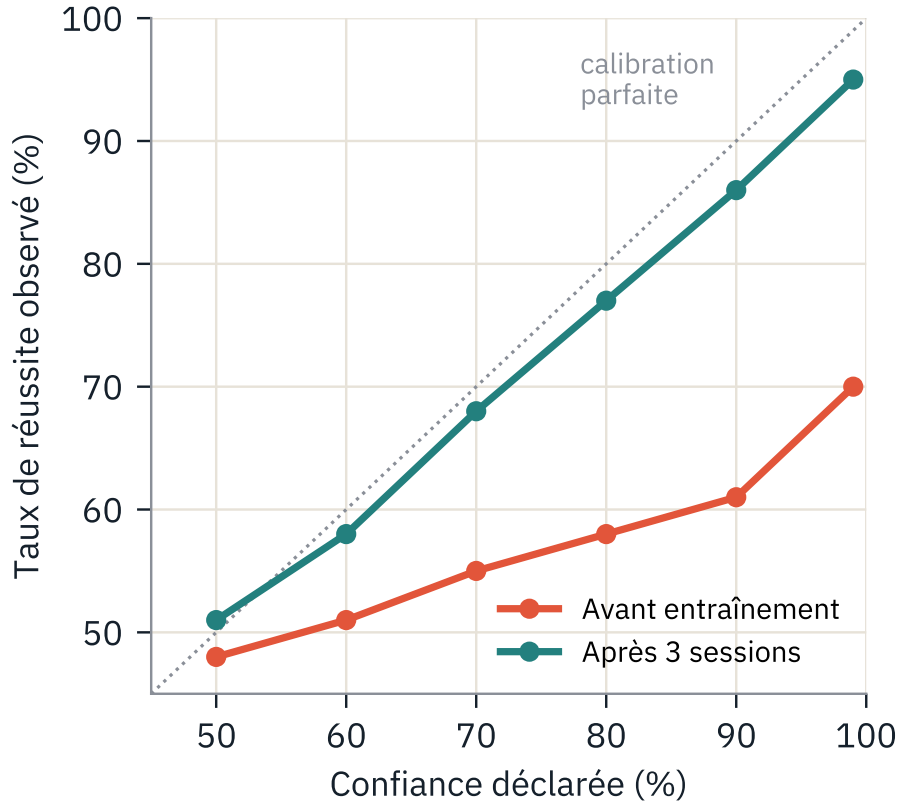


Figure 9. Calibration d'un groupe d'experts, avant et après entraînement. Sur la diagonale, confiance déclarée = réussite observée (calibration parfaite). Avant (vermillon), les experts sont *sur-confiants* : à 90 % de confiance affichée, 61 % de réussite réelle. Après trois sessions (sarcelle), la courbe se rapproche de la diagonale. Les mêmes experts, mieux calibrés, produisent des intervalles enfin honnêtes — et donc des simulations crédibles.

FIL ROUGE BIOVAX — POURQUOI LA CALIBRATION A CHANGÉ LE RÉSULTAT

Lors du premier atelier de chiffrage, l'équipe R&D estimait la durée d'arrêt à « 3 à 5 jours » — un intervalle sur-confiant typique. Après calibration et prémortem, elle l'a élargi à « 2 à 14 jours ». Ce seul ajustement a *doublé* le quantile à 95 % de la perte : la queue, auparavant invisible, est devenue le vrai sujet de la décision. Un intervalle honnête vaut mieux qu'un faux point rassurant.

✓ À RETENIR

L'analyste est l'instrument ; ses biais sont systématiques donc corrigeables. Méfiez-vous de la **disponibilité**, de l'**ancrage**, de l'**excès de confiance** et de la **conformité** de groupe. Corrigez par l'**entraînement à la calibration**, l'**équivalent-pari**, l'**estimation individuelle avant mise en commun**, le **prémortem** et la **décomposition**. Les échelles ordinales masquent les biais ; les probabilités et intervalles les exposent.

CHAPITRE 07 — RISQUE & DÉCISION

Défendre un chiffre devant une **direction**

L'IDÉE CLÉ EN UNE PHRASE

Une analyse de risque ne vaut que par la **décision qu'elle éclaire** : votre travail s'achève quand une direction, comprenant l'incertitude, choisit en connaissance de cause entre réduire, transférer, accepter ou éviter — et peut assumer ce choix.

Le raisonnement — relier le risque aux quatre leviers

Un risque chiffré ouvre quatre options, et quatre seulement. **Réduire** (investir dans des contrôles qui abaissent fréquence ou ampleur) ; **transférer** (cyber-assurance, clauses contractuelles) ; **accepter** (le risque tient sous la tolérance, on le documente et on le surveille) ; **éviter** (renoncer à l'activité qui le porte). Le rôle de l'analyste n'est pas de choisir à la place de la direction, mais de *mettre en regard* le coût de chaque levier et la réduction de risque attendue, incertitude comprise.

La puissance de l'approche quantitative éclate ici. Avec FAIR, « réduire » se chiffre en delta de perte annuelle attendue ; « transférer » se modélise en découpant la distribution (franchise, limite, prime) ; « accepter » se justifie en montrant que la courbe d'excédance reste sous la tolérance. Chaque levier devient comparable, dans la même unité : l'euro.

Exemple chiffré — arbitrer les quatre leviers chez BioVax

Tableau 3. Comparaison chiffrée des leviers de traitement (perte annuelle attendue et quantiles, en M€, issus de la simulation).

Levier	Perte attendue	P95	P99	Coût annuel	Lecture
Ne rien faire (courant)	0,85	5,2	9,8	—	Dépasse la tolérance entre 3 et 8 M€
Réduire (plan de traitement)	0,26	2,3	4,8	0,38	ROSI ≈ +55 % ; ramène sous tolérance
Transférer (assurance 1 M€ / 10 M€)	0,96	1,8	1,8	0,75 (prime)	Écrête la queue, ne baisse pas la moyenne
Combiner (réduire + transférer)	0,39	1,3	1,4	1,05	Moyenne *et* queue maîtrisées

Le tableau raconte une histoire qu'aucune matrice ordinale ne saurait porter. **Réduire** abaisse à la fois la moyenne et la queue, avec un retour positif : c'est le socle de la décision. **Transférer** seul ne touche pas la perte attendue mais *écrête la catastrophe* — l'assurance ramène le P99 de 9,8 à 1,8 M€, en échange d'une

prime. La **combinaison** des deux maîtrise les deux dimensions. La recommandation s'écrit alors sans ambiguïté : réduire d'abord, transférer le risque résiduel de queue, accepter et surveiller le reste.

> **I** LE TRANSFERT NE FAIT PAS DISPARAÎTRE LE RISQUE
>
> Une cyber-assurance découpe la distribution : elle prend en charge la tranche entre la franchise et la limite, moyennant prime. Elle réduit la *volatilité* (le P99), pas l'espérance de perte — qui augmente même, du montant de la prime. Et elle ne couvre ni la réputation durable, ni la perte d'avantage concurrentiel, ni les exclusions contractuelles. À présenter comme un lissage de la queue, jamais comme une solution au risque.

Défendre le chiffre — la posture face au COMEX

Produire le nombre est la partie facile. Le défendre devant une direction qui n'a ni le temps ni le goût des distributions exige une discipline de restitution. Quelques principes éprouvés :

- **Ouvrir par la décision, pas par la méthode.** « Nous recommandons d'investir 0,38 M€ pour éviter 0,59 M€ de perte annuelle attendue et sortir de la zone qui dépasse votre tolérance. » La méthode vient après, si on la demande.
- **Montrer la courbe d'excédance, pas le tableau brut.** Un graphique qui croise le risque et la tolérance déclarée *par la direction elle-même* emporte l'adhésion mieux que n'importe quelle colonne de chiffres.
- **Assumer l'incertitude comme une force.** « Nous sommes sûrs à 90 % que la perte de queue tombe entre X et Y » est plus crédible qu'un faux chiffre précis. Une direction expérimentée se méfie des certitudes, pas des fourchettes honnêtes.
- **Tracer chaque hypothèse.** Toute cotation, toute distribution, toute source doit être justifiée et réévaluable. C'est ce qui permet de défendre le chiffre sous le feu des questions — et de le corriger sans tout refaire.
- **Nommer le décideur et le seuil.** EBIOS l'exige dès l'atelier 1 : qui accepte le risque résiduel, et à partir de quel seuil ? Sans réponse, la réunion produit un rapport, pas une décision.

> **!** PIÈGE FRÉQUENT — VOULOIR CONVAINCRE PAR LA RIGUEUR TECHNIQUE
>
> Dérouler la taxonomie FAIR ou les cinq ateliers EBIOS devant un COMEX est le meilleur moyen de perdre la salle. La direction n'achète pas une méthode, elle achète une *décision défendable*. Gardez la mécanique pour l'annexe et les experts ; en séance, parlez euros, tolérance et options. Le respect de la méthode se voit à la solidité des réponses sous questions, pas à la densité des transparents.

> FIL ROUGE BIOVAX — LA DÉCISION FINALE
>
> La direction a validé le plan de traitement (réduction), mandaté une cyber-assurance pour la queue au-delà de 1 M€, et **accepté formellement** de maintenir R3 (vol via le prestataire) à un niveau résiduel élevé : le prestataire résistait aux mesures, et la piste retenue — entrer à son capital ou en changer — relève d'un arbitrage de gouvernance, pas de sécurité. Elle a par ailleurs placé la menace cybercriminelle sous surveillance. Décision assumée, tracée, datée, avec un responsable nommé et une revue à six mois. C'est là que l'analyse de risque atteint son but.

✓ **À RETENIR**

Quatre leviers : réduire, transférer, accepter, éviter — tous comparables en euros grâce à la quantification. On **réduit** pour baisser moyenne et queue, on **transfère** pour écrêter la catastrophe, on **accepte** sous la tolérance, on **évite** en dernier recours. Face au COMEX, ouvrez par la décision, montrez la courbe d'excédance, assumez l'incertitude, tracez les hypothèses et nommez le décideur. Une analyse ne vaut que par la décision qu'elle rend possible.

ANNEXE A — SOURCES VÉRIFIÉES

Bibliographie **annotée** & liens

Sources vérifiées en octobre 2026. Les versions et dates indiquées sont celles en vigueur à la rédaction ; les référentiels évoluant, vérifiez toujours l'édition courante sur le site de l'éditeur.

ANSSI & cadre français

A1 **ANSSI — Guide EBIOS Risk Manager, version 1.5** (septembre 2024, réf. ANSSI-PA-048). La référence méthodologique : cinq ateliers, cas fil rouge de la société de biotechnologie, termes et définitions. Désormais pleinement conforme à ISO 27005:2022.
https://cyber.gouv.fr/sites/default/files/document/20240901_Guide-EBIOS-RM-V1.5.pdf

A2 **ANSSI — « L'ANSSI met à jour la méthode EBIOS Risk Manager »** (26 mars 2024). Annonce de la mise à jour et de l'alignement ISO 27005:2022.
https://cyber.gouv.fr/actualites/lanssi-met-a-jour-la-methode-ebios-risk-manager

A3 **ANSSI — Référentiel Cyber France (ReCyF)**, version de travail, publié le 17 mars 2026. Décline NIS2 en objectifs de sécurité vérifiables, avec principe de proportionnalité à la maturité de l'entité, et un outil de comparaison avec ISO 27001/27002.
https://messervices.cyber.gouv.fr/documents-ressources/

A4 **ANSSI — Support de formation EBIOS Risk Manager** (v2.04, mai 2024, rédigé avec le Club EBIOS). Utile pour l'animation d'ateliers.
https://cyber.gouv.fr/sites/default/files/document/Support%20de%20Formation.pdf

Open FAIR & FAIR Institute

A5 **The Open Group — Risk Taxonomy (O-RT) Standard, version 3.1** (document C251, 22 mai 2025). Définition et taxonomie du risque ; décompose LEF et LM. Version courante, intègre la fonction Govern du NIST CSF 2.0.
https://pubs.opengroup.org/security/o-rt

A6 **The Open Group — Risk Analysis (O-RA) Standard, version 2.1** (document C250, 22 mai 2025). Processus d'analyse quantitative, compagnon de l'O-RT.
https://pubs.opengroup.org/security/o-ra

A7 **FAIR Institute — FAIR Controls Analytics Model (FAIR-CAM), Standard v1.0** (janvier 2025). « Physiologie » des contrôles en trois domaines (événement de perte, gestion de la variance, aide à la décision).
https://www.fairinstitute.org/

A8 **FAIR Institute — FAIR Materiality Assessment Model (FAIR-MAM), v1.0**. Modèle de coûts détaillé pour l'estimation de la perte et la matérialité (ex. divulgations SEC).
https://www.fairinstitute.org/blog/how-the-fair-crm-framework-builds-on-and-complements-open-fair

Normes ISO

A9 **ISO/IEC 27005:2022** — *Information security, cybersecurity and privacy protection — Guidance on managing information security risks* (4e édition, octobre 2022, 62 p.). Spécialise ISO 31000 pour la sécurité de l'information ; aligne le vocabulaire avec ISO 27001:2022. Référentiel de conformité d'EBIOS RM v1.5.
https://www.iso.org/standard/80585.html

A10 **ISO 31000:2018** — *Management du risque — Lignes directrices*. Cadre générique dont ISO 27005 et EBIOS RM héritent la logique de processus.
https://www.iso.org/iso-31000-risk-management.html

A11 **ISO/IEC 27001:2022 & 27002:2022** — Exigences du SMSI et catalogue des mesures de sécurité. Les mesures du 27002 alimentent les plans de traitement.
https://www.iso.org/standard/27001

— Quantification & décision

A12 **D. W. Hubbard & R. Seiersen —** *How to Measure Anything in Cybersecurity Risk*, **2e édition** (Wiley, 2023). La référence sur la mesure, la calibration, le Monte-Carlo appliqué au cyber ; introduit le « Rapid Risk Audit » et des exemples bayésiens à données rares. Préface de Jack Jones.
https://www.howtomeasureanything.com/cybersecurity/

A13 **D. W. Hubbard —** *How to Measure Anything: Finding the Value of Intangibles in Business* (Wiley). Fondations de la calibration et de l'estimation par intervalles.
https://www.howtomeasureanything.com/

A14 **D. Kahneman —** *Thinking, Fast and Slow* (2011). Référence grand public sur disponibilité, ancrage, excès de confiance et erreur de conjonction — les biais du chapitre 6.

ANNEXE B — GLOSSAIRE CROISÉ

EBIOS RM, FAIR et **ISO 27005**

Le même objet porte trois noms selon le référentiel. Ce tableau évite les quiproquos en atelier mixte et facilite le passage d'un cadre à l'autre.

Tableau 4. Correspondance terminologique entre les trois cadres.

Concept	EBIOS Risk Manager	Open FAIR	ISO 27005:2022
Ce qui agit	Source de risque (SR)	Threat agent / community	Source de risque
Actif à protéger	Valeur métier	Asset (primary stakeholder)	Bien primaire
Support technique	Bien support	Asset (composant)	Bien support
Atteinte subie	Événement redouté	Loss event	Conséquence
Intensité de l'atteinte	Gravité (G1–G4)	Loss Magnitude (€)	Conséquence (niveau)
Probabilité de réalisation	Vraisemblance (V1–V4)	Loss Event Frequency	Vraisemblance
Prob. conditionnelle de succès	(implicite dans la cotation)	Vulnerability (TCap>RS)	Vulnérabilité
Acteur de l'écosystème	Partie prenante / PPC	Secondary stakeholder	Partie intéressée
Scénario complet	Scénario de risque	Loss scenario	Scénario de risque
Moyen de traitement	Mesure de sécurité	Control	Mesure (contrôle)
Reste après traitement	Risque résiduel	Residual / mitigated risk	Risque résiduel

Définitions essentielles

LEF — Loss Event Frequency. *Fréquence d'événement de perte.* Nombre probable d'événements de perte par unité de temps ; LEF = TEF × Vulnérabilité.

TEF — Threat Event Frequency. *Fréquence d'événement de menace.* Nombre probable de tentatives par unité de temps, succès ou non.

Vuln — Vulnérabilité. *Probabilité conditionnelle.* Probabilité qu'une tentative devienne une perte ; probabilité que TCap > RS.

TCap / RS. *Capacité de menace / Force de résistance.* Deux percentiles affrontés ; un contrôle agit en relevant RS.

LM — Loss Magnitude. *Ampleur de la perte.* Distribution en euros ; somme des pertes primaire et secondaire, réparties en six formes.

ALE — Annualized Loss Expectancy. *Perte annuelle attendue.* Espérance de la distribution des pertes annuelles ; ne décrit pas une année typique.

LEC — Loss Exceedance Curve. *Courbe d'excédance des pertes.* P(perte > x) en fonction de x ; se compare à la tolérance.

PERT. *Loi Beta reparamétrée.* Définie par min / mode / max ; usuelle pour durées et coûts à partir d'un avis d'expert.

PPC. *Partie prenante critique (EBIOS).* Maillon de l'écosystème susceptible de servir de vecteur d'attaque privilégié.

Paramètres du cas & **formules**

Paramètres de simulation (cas BioVax, scénario vol de R&D)

Tableau 5. Entrées de la simulation Monte-Carlo (200 000 itérations, graine fixée). Reproductibles tels quels.

Facteur FAIR	Loi	Paramètres	Justification
TEF (tentatives/an)	Lognormale	`IC90 = [0,4 ; 4]`	Concurrent actif, veille sectorielle
Vulnérabilité	PERT	`(0,04 ; 0,12 ; 0,30)`	Socle courant, réseau non cloisonné
Durée d'arrêt (jours)	PERT	`(2 ; 5 ; 14)`	Après calibration & prémortem
Coût/jour (M€)	PERT	`(0,25 ; 0,35 ; 0,60)`	Productivité R&D immobilisée
Réponse (M€)	PERT	`(0,15 ; 0,40 ; 1,20)`	Forensic, juridique, remédiation
Remplacement (M€)	PERT	`(0,10 ; 0,30 ; 0,90)`	Reconstitution d'actifs
SLEF (prob. perte secondaire)	Fixe	`0,40`	Avantage concurrentiel conditionnel
SLM — ampleur secondaire (M€)	Lognormale	`IC90 = [0,2 ; 6]`	Avance R&D perdue, queue épaisse

Résultats clés (lecture directe)

Indicateur	Inhérent	Courant	Résiduel
Perte annuelle attendue (M€)	5,68	0,85	0,26
P(au moins une perte/an)	49 %	18,5 %	8,4 %
Quantile 95 % (M€)	21,7	5,2	2,3
Quantile 99 % (M€)	35,5	9,8	4,8

Formules de poche

- **Fréquence de perte** — LEF = TEF × Vuln, avec Vuln = P(TCap > RS).
- **Perte totale d'un événement** — LM = Perte primaire + (SLEF × Perte secondaire).
- **Perte annuelle** — tirer N ~ Poisson(LEF), sommer N pertes d'événement tirées de LM.
- **ROSI** — (ALE évitée − coût du contrôle) / coût du contrôle. Chez BioVax : (0,59 − 0,38)/0,38 ≈ +55 %.
- **IC 90 % → lognormale** — $\mu = (\ln \text{bas} + \ln \text{haut})/2$; $\sigma = (\ln \text{haut} - \ln \text{bas})/3{,}29$.
- **PERT → Beta** — $\alpha = 1 + 4(\text{mode}-\text{min})/(\text{max}-\text{min})$; $\beta = 1 + 4(\text{max}-\text{mode})/(\text{max}-\text{min})$.

I LE 3,29 DE LA FORMULE LOGNORMALE

Un intervalle à 90 % couvre 1,645 écart-type de part et d'autre de la moyenne, soit 2 × 1,645 = 3,29 au total. Diviser l'écart des log-bornes par 3,29 redonne σ. Ce petit nombre revient sans cesse dès qu'on traduit un avis d'expert « entre X et Y, sûr à 90 % » en loi de probabilité.

ANNEXE D — OPÉRATIONNEL

Check-list & modèle de **note COMEX**

Check-list de l'analyste — avant de livrer

- Chaque scénario de risque relie une source, un chemin, un actif et un objectif : pas de « vulnérabilité hors contexte ».
- La vraisemblance est rapportée à une fenêtre de temps explicite (par an), jamais un simple adjectif.
- Les six formes de perte ont été passées en revue ; chacune retenue est justifiée par un mécanisme concret.
- Les estimations sont des intervalles calibrés, pas des points ; les experts ont été entraînés à la calibration.
- Le risque résiduel n'intègre que des mesures *effectivement en place*, jamais budgétées-mais-non-déployées.
- La distribution est présentée par sa moyenne *et* ses quantiles (P95, P99) ; la queue n'est pas masquée.
- La courbe d'excédance est confrontée à une tolérance déclarée par la direction, pas inventée par l'analyste.
- Chaque cotation, distribution et source est tracée et réévaluable au prochain cycle.
- Le décideur du risque résiduel est nommé ; le seuil d'acceptation est écrit.
- Un cadre de suivi existe : indicateurs, comité de pilotage, déclencheurs de réévaluation.

Squelette de note de décision au COMEX (une page)

¶ MODÈLE — NOTE D'ARBITRAGE RISQUE

1. Décision demandée. « Nous recommandons d'investir *[coût]* pour éviter *[ALE évitée]* de perte annuelle attendue et ramener le risque sous la tolérance du conseil. »

2. Le risque en une image. Courbe d'excédance actuelle vs tolérance : montrer la zone de dépassement.

3. Les options chiffrées. Tableau réduire / transférer / accepter / combiner, en perte attendue + P95/P99 + coût.

4. La recommandation. Un levier principal, un transfert de queue, un reste accepté et surveillé — avec le ROSI.

5. L'incertitude assumée. « Sûrs à 90 % que la perte de queue tombe entre X et Y. » Hypothèses clés en annexe.

6. La gouvernance. Décideur nommé, seuil d'acceptation, responsable du plan, date de revue.

✓ **LE MOT DE LA FIN**

Une analyse de risque réussie ne se reconnaît pas à l'épaisseur de son rapport, mais à la **qualité de la décision** qu'elle a rendue possible — assumée, tracée, datée, et reliée à des euros que la direction comprend. EBIOS pour construire les scénarios, FAIR pour les chiffrer, la calibration pour que les chiffres soient honnêtes, et la restitution pour que la décision tienne. C'est tout le métier.

Document de référence rédigé par **0xKuraishY** — octobre 2026. Les chiffres du cas BioVax proviennent de simulations Monte-Carlo exécutées à 200 000 itérations ; ils illustrent la démarche et n'engagent aucune organisation réelle. Les référentiels cités (ANSSI EBIOS RM v1.5, Open FAIR O-RT 3.1 / O-RA 2.1, ISO/IEC 27005:2022, FAIR-CAM/FAIR-MAM, ReCyF) évoluent : se reporter aux éditions courantes des éditeurs. Ce manuel ne constitue ni un conseil juridique, ni une prestation d'homologation.